



بنك الآفاق

AL-AFAQ BANK

صلاية استثمارية .. وآفاق عالمية | Global Horizon Banking

سياسة أمن المعلومات العامة

(Information Security Policy)

بنك الآفاق الرقمية — متوافقة مع متطلبات من المواصفة القياسية ISO/IEC 27001:2022

تصنيف الوثيقة	سري (Confidential)
مرجع الوثيقة	ISMS-DOC-05-4
الإصدار	1.0
تاريخ الوثيقة	11 سبتمبر 2026 م
معدو الوثيقة (الفريق الاستشاري)	فهد العتيبي
مالك الوثيقة	أ. سارة الحربي (مدير أمن المعلومات - CISO)

سجل التعديلات والمراجعات (Revision History)

الإصدار	التاريخ	المؤلف / المراجع	ملخص التعديلات
1.0	11-09-2026	محمد العامري والفريق الاستشاري	الإصدار الأساسي المعتمد: صياغة السياسة العامة الشاملة لأمن المعلومات لبنك الآفاق الرقمية وفق البند 5.2 ومواءمتها مع أطر ساما وسدايا.

قائمة التوزيع (Distribution)

الاسم	المنصب / المسمى الوظيفي
د. نورة القحطاني	الرئيس التنفيذي (CEO)
م. فهد العتيبي	مدير تقنية المعلومات (CIO)
أ. سارة الحربي	مدير أمن المعلومات (CISO)
أ. ليلى الدوسري	مدير إدارة الشؤون القانونية
أ. أحمد الغامدي	مدير إدارة المراجعة الداخلية
أ. خالد الشمري	مدير إدارة الموارد البشرية

الاعتماد والمصادقة (Approval)

الاسم	المنصب	حالة الاعتماد	التاريخ
د. نورة القحطاني	الرئيس التنفيذي	معتمد (تنفيذياً)	11-09-2026
أ. سارة الحربي	مدير أمن المعلومات	تمت المراجعة والتأكيد (تقنياً)	11-09-2026
أ. عبدالله المحيسن	رئيس مجلس الإدارة	مصادق عليه ومفعّل (مجلس الإدارة)	11-09-2026

المحتويات (Contents)

1	المقدمة.....	8
2	سياسة أمن المعلومات.....	10
2.1	متطلبات أمن المعلومات.....	10
2.2	إطار عمل تحديد الأهداف.....	10
2.3	التحسين المستمر لنظام إدارة أمن المعلومات (ISMS).....	11
2.4	مجالات سياسة أمن المعلومات.....	11
2.5	تطبيق سياسة أمن المعلومات.....	14

الجدول

الجدول 1: مجموعة وثائق السياسة..... 14

1. المقدمة

يحدد هذا المستند سياسة أمن المعلومات الخاصة ببنك الأفاق الرقمية .

وبصفتها مؤسسة أعمال حديثة وتتطلع إلى المستقبل، تدرك بنك الأفاق الرقمية على مستوى الإدارة العليا الحاجة إلى ضمان سير أعمالها بسلاسة ودون انقطاع، بما يحقق مصلحة عملائها ومساهميها وسائر الأطراف المعنية.

ومن أجل توفير هذا المستوى من استمرارية العمليات التشغيلية، قامت بنك الأفاق الرقمية بتطبيق نظام إدارة أمن المعلومات (ISMS) بما يتماشى مع المعيار الدولي لأمن المعلومات ISO/IEC 27001 ، والذي يحدد متطلبات نظام إدارة أمن المعلومات استناداً إلى أفضل الممارسات المعترف بها دولياً.

يحقق تشغيل نظام إدارة أمن المعلومات العديد من الفوائد للمنظمة، بما في ذلك:

- حماية الإيرادات والربحية: حماية مصادر الإيرادات وتعزيز ربحية البنك واستقراره المالي.
- موثوقية الخدمات المصرفية: ضمان استمرارية تقديم الخدمات والمنتجات المصرفية الرقمية للعملاء دون انقطاع.
- صون سمعة المؤسسة وقيمة الأسهم: حماية مكانة البنك وسمعته وتعظيم القيمة الاستثمارية للمساهمين.
- الامتثال التشريعي والتنظيمي: الامتثال الكامل لإطار الأمن السيبراني الصادر عن البنك المركزي السعودي (ساما)، ونظام حماية البيانات الشخصية الصادر عن (سدايا)، وكافة الأنظمة الوطنية والدولية ذات الصلة.

قررت بنك الأفاق الرقمية الحفاظ على الاعتماد الكامل لشهادة ISO/IEC 27001 لضمان التحقق من التطبيق الفعال لأفضل ممارسات أمن المعلومات من قبل طرف ثالث مستقل، وهي جهة منح شهادات مسجلة ومعتمدة (RCB).

تنطبق هذه السياسة على كافة الأنظمة والأفراد والعمليات التي تشكل نظم المعلومات في المنظمة، بما في ذلك أعضاء مجلس الإدارة، والمديرون، والموظفون، والموردون، والأطراف الخارجية الأخرى التي تملك صلاحية الوصول إلى أنظمة بنك الأفاق الرقمية .

تستند هذه السياسة المظلية إلى حزمة من الوثائق والسياسات والإجراءات التشغيلية الداعمة المعمول بها في البنك، والمبينة تفصيلاً في الجدول رقم 1 من هذه الوثيقة.

2. سياسة أمن المعلومات العامة

2.1 متطلبات أمن المعلومات والامتثال التنظيمي

سيتم الاتفاق على تحديد واضح لمتطلبات أمن المعلومات داخل بنك الأفاق وتحديثه بالتعاون مع قطاعات الأعمال الداخلية، بحيث تركز كافة أنشطة نظام إدارة أمن المعلومات (ISMS) على تلبية تلك المتطلبات. كما سيتم توثيق المتطلبات النظامية والتنظيمية والتعاقدية وتقديمها كمدخلات في عملية التخطيط. وسيتم استيفاء وتحديد المتطلبات الخاصة بأمن الأنظمة أو الخدمات الجديدة أو المعدلة كجزء أساسي من مرحلة التصميم في كل مشروع.

ويُعد توجيه الضوابط الأمنية المطبقة استناداً إلى احتياجات الأعمال مبدأً جوهرياً في نظام إدارة أمن المعلومات التابع لـ بنك الأفاق وسيتم إيضاح وتعميم هذا المبدأ بانتظام على كافة الموظفين من خلال اجتماعات فرق العمل والوثائق الموجزة والتوجيهية.

2.2 إطار وضع ومتابعة أهداف أمن المعلومات

سيتم اتباع دورة منتظمة لتحديد أهداف أمن المعلومات لتتزامن مع دورة تخطيط الميزانية، مما يضمن الحصول على التمويل الكافي لأنشطة التحسين المحددة. وستستند هذه الأهداف إلى فهم واضح لمتطلبات الأعمال، مسترشدة بنتائج عملية مراجعة الإدارة التي قد يتم خلالها استطلاع آراء الأطراف المعنية ذات الصلة.

سيتم توثيق أهداف أمن المعلومات لفترة زمنية متفق عليها، إلى جانب تفاصيل آليات تحقيقها. وستخضع هذه الأهداف للتقييم والمراقبة ضمن مراجعات الإدارة لضمان استمرار فاعليتها وملاءمتها. وفي حال تطلب الأمر إجراء أي تعديلات، فستتم إدارتها عبر عملية إدارة التغيير.

وفقاً لمعيار ISO/IEC 27001 ، ستعتمد بنك الأفاق الضوابط المرجعية المفصلة في الملحق (أ) (Annex A) من المعيار حيثما كان ذلك مناسباً. وتتم مراجعة هذه الضوابط بصورة منتظمة في ضوء نتائج تقييمات المخاطر وتماشياً مع خطط معالجة مخاطر أمن المعلومات. وللإطلاع على تفاصيل ضوابط الملحق (أ) التي تم تطبيقها وتلك التي تم استثنائها، يُرجى الرجوع إلى وثيقة "بيان انطباق الضوابط" (Statement of Applicability).

بالإضافة إلى ذلك، سيتم اعتماد وتطبيق ضوابط محسنة وإضافية من مدونات الممارسات التالية عند الاقتضاء:

- ISO/IEC 27002: دليل الممارسات لإدارة ضوابط أمن المعلومات.
- ISO/IEC 27017: دليل ضوابط أمن المعلومات لخدمات الحوسبة السحابية (المعتمدة لبيئة AWS الخاصة بالبنك).
- ISO/IEC 27018: دليل حماية معلومات التعريف الشخصية (PII) في السحابة العامة لضمان الامتثال لنظام حماية البيانات الشخصية.

إن تبني واعتماد مدونات الممارسات هذه سيوفر ضماناً إضافياً لعملائنا، ويسهم بصورة أكبر في امتثالنا للتشريعات الدولية الخاصة بحماية البيانات.

2.3 التحسين والتطوير المستمر لنظام الـ ISMS

- تتمثل سياسة بنك الأفاق الرقمية بشأن التحسين المستمر في:

- التحسين المستمر لفاعلية نظام إدارة أمن المعلومات (ISMS).
 - تطوير العمليات الحالية ومواءمتها مع أفضل الممارسات المحددة في معيار ISO/IEC 27001 والمعايير ذات الصلة.
 - الحصول على شهادة الاعتماد لمعيار ISO/IEC 27001 والمحافظة عليها بصورة مستمرة.
 - رفع مستوى الاستباقية (وانطباع الأطراف المعنية حول هذا النهج الاستباقي) فيما يتعلق بأمن المعلومات.
 - جعل عمليات وضوابط أمن المعلومات أكثر قابلية للقياس لتوفير أساس متين لاتخاذ قرارات مدروسة وموثوقة.
 - مراجعة مؤشرات ومقاييس الأداء ذات الصلة بصفة سنوية لتقييم مدى ملائمة تعديلها، استناداً إلى البيانات التاريخية المجمعة.
 - استخلاص مقترحات وأفكار التحسين عبر الاجتماعات الدورية وغيرها من قنوات التواصل مع الأطراف المعنية.
 - مراجعة أفكار التحسين في اجتماعات الإدارة الدورية لتحديد أولوياتها وتقييم جدولها الزمنية ومردودها المتوقع.
- يمكن استقاء أفكار ومقترحات التحسين من أي مصدر، بما في ذلك الموظفون، والعلماء، والموردون، وفرق تقنية المعلومات، وتقييمات المخاطر، وتقارير الخدمات. وبمجرد تحديد هذه الأفكار، سيتم تسجيلها وتقييمها كجزء أساسي من مراجعات الإدارة.

2.4 محاور وحزم سياسات أمن المعلومات التفصيلية (جدول 1)

تحدد بنك الأفاق الرقمية سياسات في مجالات متعددة وواسعة مرتبطة بأمن المعلومات، والموضحة بالتفصيل في مجموعة شاملة من وثائق السياسات المرافقة لسياسة أمن المعلومات العامة والشاملة هذه.

يتم إعداد وتحديد كل سياسة من هذه السياسات والاتفاق عليها من قبل شخص أو أكثر من ذوي الكفاءة والاختصاص في المجال المعني، وفور اعتمادها رسمياً، يتم تعميمها وإبلاغها للفئات والجهات المستهدفة المناسبة، سواء داخل المنظمة أو خارجها.

يوضح الجدول أدناه السياسات الفردية ضمن مجموعة الوثائق، ويلخص محتوى كل سياسة منها والجمهور المستهدف من الأطراف المعنية.

الجمهور المستهدف	المجالات التي تتناولها	عنوان السياسة
مستخدمو خدمة الإنترنت	الاستخدام المهني للإنترنت، الاستخدام الشخصي للإنترنت، إدارة حسابات الإنترنت، الأمان والمراقبة، والاستخدامات المحظورة لخدمة الإنترنت	سياسة الوصول إلى الإنترنت (Internet Access Policy)
الموظفون المعنيون بشراء وإدارة الخدمات السحابية	العناية الواجبة، والتسجيل، والإعداد، وإدارة خدمات الحوسبة السحابية. والغاؤها	سياسة الحوسبة السحابية (Cloud Computing Policy)
مستخدمو الأجهزة المحمولة المقدمة من الشركة	العناية بأجهزة الحاسوب المحمولة والأجهزة اللوحية والهواتف الذكية وتأمينها، سواء كانت مقدمة من قبل المنظمة للاستخدام في العمل	سياسة الأجهزة المحمولة (Mobile Device Policy)
مستخدمو الأجهزة الشخصية للاستخدام المقيد في العمل	عندما يرغب الموظفون في (BYOD) اعتبارات إحضار الأجهزة الشخصية. استخدام أجهزتهم المحمولة الخاصة للوصول إلى معلومات المنظمة	سياسة استخدام الأجهزة الشخصية في العمل (BYOD Policy)
الإدارة والموظفون المعنيون بإعداد موقع العمل عن بُعد وصيانتته	اعتبارات أمن المعلومات عند إنشاء وإدارة مواقع وترتيبات العمل عن بُعد؛ مثل: الأمان المادي، والتأمين، والمعدات	سياسة العمل عن بُعد (Teleworking Policy)
الموظفون المعنيون بإعداد وإدارة التحكم في الوصول	تسجيل المستخدمين وإلغاء تسجيلهم، ومنح حقوق وصلاحيات الوصول، والوصول الخارجي، ومراجعات الوصول، وسياسة كلمات المرور، ومسؤوليات المستخدمين، والتحكم في الوصول إلى الأنظمة والتطبيقات	سياسة التحكم في الوصول (Access Control Policy)
مالكو الأصول وفريق تقنية المعلومات والاتصالات (ICT)	إمكانية تطبيق واستخدام ضوابط الوصول الديناميكية المتاحة في بيئات محددة	سياسة التحكم الديناميكي في الوصول (Dynamic Access Control Policy)
الموظفون المعنيون بإعداد وإدارة استخدام تقنيات وأسابيب	تقييم المخاطر، واختيار التقنيات، والنشر، والاختبار، ومراجعة التشفير، وإدارة المفاتيح	سياسة التشفير (Cryptographic Policy)

بنك الآفاق الرقمية | سياسة أمن المعلومات العامة

التشفير		
جميع الموظفين	المناطق الآمنة، وأمان الوثائق الورقية والمعدات، وإدارة دورة حياة المعدات	سياسة الأمان المادي (Physical Security Policy)
الموظفون المسؤولون عن حماية البنية التحتية للمنظمة من البرمجيات الخبيثة	(Spam) جدران الحماية، ومكافحة الفيروسات، وتصفية البريد المزعج وتثبيت البرمجيات وفحصها، وإدارة الثغرات، وتدريب وتوعية المستخدمين، ومراقبة التهديدات والتنبيهات، والمراجعات التقنية، وإدارة حوادث البرمجيات الخبيثة.	سياسة مكافحة البرمجيات الخبيثة (Anti-Malware Policy)
الموظفون المسؤولون عن تصميم وتطبيق أنظمة النسخ الاحتياطي	دورات النسخ الاحتياطي، والنسخ الاحتياطي السحابي، والتخزين خارج الموقع، والتوثيق، واختبار الاسترداد، وحماية وسائط التخزين	سياسة النسخ الاحتياطي (Backup Policy)
الموظفون المسؤولون عن حماية البنية التحتية للمنظمة من الهجمات	إعدادات جمع الأحداث وحمايتها ومراجعتها	سياسة تسجيل الأحداث والمراقبة (Logging and Monitoring Policy)
جميع الموظفين	شراء البرمجيات، وتسجيلها، وتثبيتها وإزالتها، وتطوير البرمجيات داخلياً، واستخدام البرمجيات في السحابة	سياسة البرمجيات (Software Policy)
الموظفون المسؤولون عن حماية البنية التحتية للمنظمة من البرمجيات الخبيثة	تعريف الثغرات، ومصادر المعلومات، والتصحيحات والتحديثات، وتقييم الثغرات، والتدريب التوعوي، والإفصاح عن الثغرات (Hardening) والتحصين الأمني	سياسة إدارة الثغرات الأمنية التقنية (Technical Vulnerability Management Policy)
الموظفون المسؤولون عن تصميم الشبكات وتنفيذها وإدارتها	تصميم أمان الشبكة (بما في ذلك تجزئة الشبكات، وأمن المحيط، والشبكات اللاسلكية، والوصول عن بُعد)؛ وإدارة أمان الشبكة (بما في ذلك الأدوار والمسؤوليات، والتسجيل والمراقبة، وإدارة التغييرات)	سياسة أمان الشبكات (Network Security Policy)
مستخدمو وسائل المراسلة الإلكترونية	إرسال واستقبال الرسائل الإلكترونية، ومراقبة وسائل المراسلة الإلكترونية، واستخدام البريد الإلكتروني	سياسة المراسلات الإلكترونية (Electronic Messaging Policy)
مستخدمو أدوات التعاون والعمل التشاركي عبر الإنترنت	استخدام أدوات التعاون والتشارك للتواصل، والمشاركة، وعقد الاجتماعات عبر الفيديو	سياسة التعاون عبر الإنترنت (Online Collaboration Policy)
الموظفون المسؤولون عن تصميم وإدارة وكتابة الشيفرات البرمجية لتطوير البرمجيات المخصصة	توصيف متطلبات الأعمال، وتصميم الأنظمة، والتطوير والاختبار، وتطوير البرمجيات المسند إلى جهات خارجية	سياسة التطوير الآمن (Secure Development Policy)
الموظفون المعنيون بإنشاء وإدارة العلاقات مع الموردين	العناية الواجبة، واتفاقيات الموردين، ومراقبة الخدمات ومراجعتها، والتغييرات، والنزاعات، وإنهاء العقود	سياسة أمن المعلومات في العلاقات مع الموردين (Information Security Policy for Supplier Relationships)
الموظفون المسؤولون عن تصميم الأنظمة وإدارة تقديم الخدمات	متطلبات وتصميم التوافرية، والمراقبة وإعداد التقارير، وحالات عدم التوافر، واختبار خطط التوافرية، وإدارة التغييرات	سياسة إدارة التوافرية (Availability Management Policy)
جميع الموظفين	حماية الملكية الفكرية، والقانون، والعقوبات، والامتثال لتراخيص البرمجيات	سياسة الامتثال للملكية الفكرية وحقوق النشر (IP and Copyright Compliance Policy)
الموظفون المسؤولون عن إنشاء السجلات وإدارتها	فترات الاحتفاظ لأنواع محددة من السجلات، واستخدام التشفير، واختيار وسائط التخزين، واسترجاع السجلات، وإتلافها ومراجعتها	سياسة حماية السجلات والاحتفاظ بها (Records Retention and Protection Policy)
الموظفون المسؤولون عن تصميم وإدارة الأنظمة التي تستخدم البيانات الشخصية	تشريعات حماية البيانات المعمول بها، والتعريفات، والمتطلبات	سياسة الخصوصية وحماية البيانات الشخصية (Privacy and Personal Data Protection Policy)
جميع الموظفين	أمان المعلومات المعروضة على الشاشات، والمطبوعة، والمخزنة على وسائط	سياسة المكتب النظيف والشاشة

النظيفة (Clear Desk and Clear Screen Policy)	التخزين القابلة للإزالة.	
سياسة وسائل التواصل الاجتماعي (Social Media Policy)	إرشادات حول كيفية استخدام وسائل التواصل الاجتماعي عند تمثيل المنظمة وعند مناقشة قضايا ذات صلة بها.	جميع الموظفين
سياسة أمن الموارد البشرية (HR Security Policy)	التوظيف، وعقود العمل، والامتثال للسياسات، والإجراءات التأديبية، وإنهاء الخدمة.	جميع الموظفين
سياسة الاستخدام المقبول (Acceptable Use Policy)	التزام الموظف بسياسات أمن المعلومات في المنظمة.	جميع الموظفين
سياسة إدارة الأصول (Asset Management Policy)	يحدد هذا المستند قواعد كيفية إدارة الأصول من منظور أمن المعلومات.	جميع الموظفين
سياسة كاميرات المراقبة (CCTV Policy)	استخدام كاميرات المراقبة التلفزيونية في الأماكن المادي، بما في ذلك تحديد المواقع وقضايا واعتبارات حماية البيانات.	الموظفون المسؤولون عن كاميرات المراقبة (CCTV)
سياسة إدارة التكوين (Configuration Management Policy)	التكوين الآمن للأجهزة، والبرمجيات، والخدمات، والشبكات.	الموظفون المسؤولون عن تصميم الأنظمة وإدارة تقديم الخدمات
سياسة حذف المعلومات (Information Deletion Policy)	حذف المعلومات المخزنة في أنظمة المعلومات أو الأجهزة أو في أي وسائط تخزين أخرى عند انتهاء الحاجة إليها.	الموظفون المسؤولون عن تصميم وإدارة الأنظمة التي تستخدم البيانات الشخصية
سياسة حجب البيانات (Data Masking Policy)	والاسم (Anonymization) استخدام تقنيات حجب البيانات مثل إخفاء الهوية لحماية معلومات تحديد الهوية الشخصية (Pseudonymization) المستعار (PII).	الموظفون المسؤولون عن تصميم وإدارة الأنظمة التي تستخدم البيانات الشخصية
سياسة منع تسريب البيانات (Data Leakage Prevention Policy)	ضبط وتكوين أدوات البرمجيات ذات الصلة لاكتشاف ومنع تسريب البيانات.	الموظفون المسؤولون عن تصميم الأنظمة وإدارة تقديم الخدمات
سياسة المراقبة (Monitoring Policy)	مراقبة بيئة تكنولوجيا المعلومات والاتصالات لاكتشاف الأنشطة الشاذة أو غير الطبيعية.	الموظفون المسؤولون عن تصميم الأنظمة وإدارة تقديم الخدمات
سياسة تصفية الويب (Web Filtering Policy)	تقييد الوصول إلى مواقع الإنترنت التي تُعد غير ملائمة.	الموظفون المسؤولون عن تصميم الأنظمة وإدارة تقديم الخدمات
سياسة البرمجة الآمنة (Secure Coding Policy)	المبادئ المتبعة عند تطوير شيفرة برمجية آمنة.	الموظفون المسؤولون عن تصميم وإدارة وكتابة الشيفرات البرمجية لتطوير البرمجيات المخصصة
سياسة استخبارات التهديدات (Threat Intelligence Policy)	جمع واستخدام استخبارات التهديدات على المستويات الاستراتيجية والتكتيكية والتشغيلية.	الموظفون المسؤولون عن حماية البنية التحتية للمنظمة من الهجمات
سياسة الإبلاغ عن المخالفات في أمن المعلومات (Information Security Whistleblowing Policy)	إثارة وتصعيد الملاحظات والقضايا المتعلقة بأمن المعلومات داخل المنظمة.	جميع الموظفين وسائر الأطراف المعنية

2.5 تطبيق وإنفاذ سياسة أمن المعلومات (Application & Compliance)

تمت مراجعة واعتماد بنود السياسات الواردة في هذا المستند ومجموعة السياسات الداعمة المدرجة في الجدول 1 من قبل الإدارة العليا لبنك الأفاق ، ويجب الامتثال التام لها. وقد يؤدي عدم التزام الموظف بهذه السياسات إلى اتخاذ إجراءات تأديبية بحقه وفقاً لـ «إجراءات تأديب الموظفين» (Employee Disciplinary Process) المعتمدة في المنظمة.

ينبغي توجيه أي استفسارات بشأن أي سياسة من سياسات بنك الأفاق إلى المدير المباشر للموظف في المقام الأول.